

EXECUTIVE SUMMARY

Cyber Resilience Act (CRA)

Guida rapida per il management aziendale

Cosa devi sapere in 10 minuti

TIPO DOCUMENTO:

Guida Executive — Lettura rapida 10 minuti

Regolamento (UE) 2024/2847 · Cyber Resilience Act

Conformità obbligatoria: 11 dicembre 2027 · Edizione 2025

Cos'è il Cyber Resilience Act (CRA)?

10 dic 2024

Data di entrata in vigore

11 set 2026Obbligo segnalazione
vulnerabilità**11 dic 2027**

Conformità Obbligatoria

€ 15 MSanzione massima per
violazione

Il **Cyber Resilience Act** (abbreviazione: **CRA**, traduzione: *Legge sulla Resilienza Cibernetica*) è il **Regolamento (UE) 2024/2847**, pubblicato nella Gazzetta Ufficiale dell'Unione Europea il 20 novembre 2024 ed entrato in vigore il 10 dicembre 2024. È la prima legge europea che impone requisiti obbligatori di cybersicurezza per tutti i prodotti digitali venduti nell'Unione Europea.

Fino ad oggi non esisteva una normativa europea uniforme sulla sicurezza informatica dei prodotti: ogni Paese aveva regole diverse, e molti prodotti arrivavano sul mercato con gravi vulnerabilità. Il CRA cambia radicalmente questa situazione: dal **11 dicembre 2027**, nessun prodotto digitale potrà essere venduto nell'UE senza soddisfare requisiti minimi di sicurezza obbligatori.

■ Analogia pratica:

Il CRA per la cybersicurezza è come le norme di sicurezza elettrica per gli elettrodomestici. Così come una lavatrice deve avere il marchio CE per essere venduta in Europa (garantisce che non provoca scosse o incendi), dal 2027 ogni prodotto digitale dovrà dimostrare di rispettare standard minimi di sicurezza informatica prima di poter entrare nel mercato UE.

Chi riguarda il CRA?

Il CRA si applica a chiunque produca, importi o distribuisca nell'UE un **Prodotto con Elementi Digitali** (abbreviato: **PDE**). La definizione legale (Art. 3, par. 1) comprende: «*qualsiasi prodotto hardware o software e relative soluzioni di elaborazione remota dei dati, compresi i componenti hardware o software immessi sul mercato separatamente*».

■ Nel perimetro CRA

- Router Wi-Fi, modem domestici e aziendali
- Telecamere IP, NVR, sistemi di videosorveglianza
- Smart TV, smart speaker, assistenti vocali
- Termostati, serrature, lampadine intelligenti (IoT*)
- Software gestionale, ERP, CRM commerciale
- Applicazioni mobile a pagamento o con funzioni connesse
- Firmware di dispositivi industriali connessi
- Librerie software commerciali vendute separatamente
- Sistemi di controllo industriale (ICS*/SCADA*) connessi

■ Escluso dal CRA

- Dispositivi medici → soggetti a MDR* (UE) 2017/745
- Dispositivi diagnostici in vitro → IVDR (UE) 2017/746
- Veicoli a motore → Reg. (UE) 2019/2144
- Aviazione civile → Reg. (UE) 2018/1139
- Prodotti per difesa e sicurezza nazionale
- Software open source gratuito non commerciale
- Software sviluppato solo per R&S; interna
- Servizi digitali puri (SaaS* senza prodotto fisico)

■ ■ Attenzione — Produttori extra-UE:

Anche le aziende con sede fuori dall'Unione Europea (USA, Cina, India, ecc.) che vendono prodotti digitali nell'UE sono soggette al CRA. In questo caso, l'importatore europeo o un rappresentante autorizzato nominato dal produttore è responsabile della conformità.

Le quattro categorie di prodotto

CATEGORIA	DESCRIZIONE	ESEMPI PRATICI	CONFORMITÀ
■ Non Critico (categoria default)	La grande maggioranza dei prodotti digitali commerciali che non rientrano nelle liste degli Allegati III e IV del Regolamento.	App mobile, software gestionale, videogiochi, dispositivi smart home semplici, stampanti connesse, smart TV.	Autovalutazione interna: il fabbricante verifica autonomamente la conformità, compila la documentazione e firma la Dichiarazione di Conformità UE.
■ Critico Classe I	Prodotti con funzioni di sicurezza o la cui compromissione potrebbe impattare molti utenti o reti (Allegato III, Parte 1).	Browser Internet, gestori di password (password manager), software antivirus, client VPN* (Virtual Private Network), router domestici.	Standard armonizzati europei oppure valutazione da un CAB* (Conformity Assessment Body — Organismo di Certificazione) terzo.
■ Critico Classe II	Prodotti per infrastrutture critiche, con funzioni di sicurezza avanzate, o che gestiscono reti importanti (Allegato III, Parte 2).	Sistemi operativi per uso industriale, firewall per reti industriali ICS/SCADA*, sistemi di controllo accessi biometrici, gestione infrastrutture di rete.	Valutazione obbligatoria da un CAB* accreditato (organismo terzo indipendente). Non è possibile l'autovalutazione.
■ Altamente Critico (componenti core)	Microprocessori e componenti hardware con funzioni critiche di sicurezza che costituiscono la base di fiducia di altri prodotti (Allegato IV).	Microprocessori con funzioni di sicurezza, chip TPM* (Trusted Platform Module), moduli HSM* (Hardware Security Module), smart card.	Schema europeo di certificazione EUCS* (EU Cybersecurity Certification Scheme) — il livello più elevato di valutazione.

Le scadenze chiave



Le sanzioni — cifre da conoscere

TIPO DI VIOLAZIONE	SANZIONE MASSIMA	BASE DI CALCOLO
Violazione requisiti essenziali di sicurezza (prodotto non conforme al mercato)	€ 15.000.000 o 2,5% del fatturato	Si applica il valore MAGGIORE tra la cifra fissa e la percentuale del fatturato MONDIALE annuo del gruppo.
Mancata segnalazione di vulnerabilità o incidenti di sicurezza nei tempi previsti	€ 10.000.000 o 2% del fatturato	Calcolato sul fatturato mondiale annuo dell'intero gruppo societario, non solo della filiale europea.
Informazioni false o incomplete fornite alle autorità di vigilanza	€ 5.000.000 o 1% del fatturato	Include: documentazione tecnica fuorviante, SBOM* (Software Bill of Materials) incompleto, dichiarazione di conformità falsa.

■ ■ Importante per le PMI* (Piccole e Medie Imprese):

Le PMI (meno di 250 dipendenti, fatturato $\leq$ 50 milioni €) e le microimprese (meno di 10 dipendenti) hanno accesso a procedure semplificate e supporto tecnico prioritario da parte degli Stati Membri. Tuttavia NON sono esentate dagli obblighi sostanziali: se vendono prodotti digitali nell'UE, devono conformarsi. La semplificazione riguarda la burocrazia, non i requisiti di sicurezza.

Cosa fare adesso — 6 azioni prioritarie

1

Verificare il perimetro

Rispondere subito alla domanda: la mia azienda produce, importa o distribuisce prodotti con elementi digitali nell'UE? Fare un inventario di tutti i prodotti (hardware e software) con connettività o funzioni digitali. Esempio: un'azienda che produce pompe industriali senza connettività è fuori perimetro; la stessa azienda che vende pompe con pannello di controllo connesso via Wi-Fi è dentro il perimetro.

2

Classificare ogni prodotto

Per ogni prodotto nel perimetro, determinare la categoria (Non critico, Classe I, II, Altamente critico) consultando gli Allegati III e IV del Regolamento disponibili su eur-lex.europa.eu. La categoria determina la procedura di conformità e i costi associati. La maggior parte dei prodotti consumer e software gestionale è 'non critica'.

3

Eseguire un gap analysis

Confrontare lo stato attuale di sicurezza con i 21 requisiti dell'Allegato I del CRA. I gap più comuni: dipendenze software con CVE* (vulnerabilità) note non corrette, password identiche per tutti i dispositivi, assenza di meccanismo di aggiornamento automatico, interfacce di debug lasciate attive, assenza di documentazione tecnica.

4

Generare l'SBOM obbligatorio

L'SBOM* (Software Bill of Materials — Distinta Base del Software) è un inventario completo di tutti i componenti software del prodotto in formato leggibile automaticamente. È obbligatorio per legge. Strumenti gratuiti: Syft o Trivy (open source). Formati richiesti: CycloneDX* o SPDX* (standard internazionali per la descrizione dei componenti software).

5

Implementare vulnerability management

Stabilire processi formali per: monitorare le CVE* nelle proprie dipendenze (abbonamento a feed NVD o ENISA), rilasciare patch di sicurezza con SLA* (Service Level Agreement — tempi massimi di risposta) definiti, segnalare le vulnerabilità attivamente sfruttate ad ENISA entro 24 ore. Pubblicare un indirizzo email (es. security@azienda.it) per ricevere segnalazioni.

6

Preparare la documentazione tecnica

Il CRA richiede un fascicolo tecnico completo: analisi del rischio di cybersicurezza, documentazione dell'architettura di sistema, risultati dei test di sicurezza, SBOM, CVD policy* (politica di divulgazione coordinata delle vulnerabilità), Dichiarazione di Conformità UE firmata, istruzioni di sicurezza per l'utente.

GUIDA OPERATIVA ESSENZIALE

Questa sezione è una guida sintetica ma completa per chi vuole capire concretamente cosa fare. Le 4 fasi sono sequenziali e coprono l'intero percorso: dalla diagnosi iniziale fino all'apposizione del marchio CE*.

F FASE A — DIAGNOSI

A1 — Inventario prodotti

Lista tutti i prodotti venduti nell'UE con elementi digitali. Per ogni prodotto: nome e versione, se è connesso a Internet (anche indirettamente), se raccoglie dati, se ha controllo remoto. Includere anche firmware di dispositivi hardware e librerie software commerciali vendute separatamente.

A2 — Verifica delle esclusioni

Controlla se qualche prodotto rientra nelle esclusioni CRA: dispositivi medici (MDR*), veicoli (Reg. 2019/2144), aviazione (Reg. 2018/1139), prodotti militari/sicurezza nazionale. Documenta per iscritto la motivazione di ogni esclusione.

A3 — Classificazione per categoria

Per i prodotti nel perimetro, determina la categoria consultando gli Allegati III e IV del Regolamento. Cerca il tipo di prodotto nelle liste: Allegato IV = Altamente critico, Allegato III Parte 2 = Classe II, Allegato III Parte 1 = Classe I, non presente negli allegati = Non critico (la maggioranza).

F FASE B — ANALISI DEL DIVARIO

B1 — Generazione SBOM

Genera un SBOM* (Software Bill of Materials — Distinta Base del Software) per ogni prodotto usando strumenti gratuiti come Syft: 'syft dir:./src -o cyclonedx-json'. L'SBOM elenca ogni componente software con versione precisa e identificatore univoco PURL*. È obbligatorio per legge e deve essere in formato CycloneDX* o SPDX*.

B2 — Vulnerability scan

Analizza l'SBOM con Gype o Trivy per trovare CVE* (Common Vulnerabilities and Exposures — vulnerabilità note catalogate) nelle dipendenze. Ogni CVE con punteggio CVSS* (Common Vulnerability Scoring System) ≥ 7.0 deve essere corretta prima del rilascio. Le CVE con CVSS ≥ 9.0 sono critiche: vanno corrette immediatamente.

B3 — Revisione configurazioni di sicurezza

Verifica: le credenziali di default sono uniche per dispositivo (no 'admin/admin' condiviso), le porte di rete non necessarie sono chiuse, le interfacce di debug sono rimosse dalle build di produzione, i dati trasmessi sono cifrati con TLS* 1.2+ (Transport Layer Security — protocollo di crittografia per le comunicazioni di rete).

F FASE C — IMPLEMENTAZIONE

C1 — Correzione dei gap

Per ogni gap identificato nella Fase B, pianifica e implementa la correzione. Aggiorna le librerie vulnerabili (es. 'npm audit fix' per JavaScript, 'pip install --upgrade' per Python), implementa password uniche per dispositivo, aggiungi crittografia TLS*, rimuovi il codice di debug dalle build di produzione.

C2 — Processo di vulnerability management

Crea un processo formale: pubblica un indirizzo security@azienda.it per ricevere segnalazioni esterne, definisci i tempi di risposta (es. patch entro 30 giorni per CVE critiche), pubblica una CVD policy* (Coordinated Vulnerability Disclosure — politica di divulgazione coordinata delle vulnerabilità) sul sito aziendale.

C3 — Documentazione tecnica

Prepara il fascicolo tecnico: descrizione del prodotto con architettura di sistema, analisi del rischio (threat modeling con metodo STRIDE*), risultati dei test di sicurezza, SBOM aggiornato, CVD policy, istruzioni di sicurezza per l'utente in italiano (e nelle lingue dei Paesi in cui il prodotto è venduto).

F**FASE D — CERTIFICAZIONE**

Mesi 12-

D1 — Valutazione di conformità

Per prodotti NON CRITICI: autovalutazione interna — verifica ogni requisito, compila il fascicolo tecnico, firma la Dichiarazione di Conformità UE. Per prodotti CLASSE I: segui gli standard armonizzati europei (pubblicati sulla Gazzetta Ufficiale UE) oppure incarica un CAB* accreditato. Per prodotti CLASSE II: valutazione CAB* obbligatoria.

D2 — Marchio CE e mantenimento

Dopo la valutazione, apponi il marchio CE* sul prodotto. Conserva il fascicolo tecnico per almeno 10 anni. Stabilisci un processo di monitoraggio continuo: vulnerability scan semestrale, aggiornamento SBOM* ad ogni nuova versione, pubblicazione security advisory ad ogni patch rilasciata.

GLOSSARIO — Tutti i termini con asterisco (*)

Ogni termine seguito da asterisco (*) nel testo è definito qui con spiegazione completa.

2FA / MFA	Two-Factor / Multi-Factor Authentication — Autenticazione a Due o Più Fattori. Metodo che richiede due o più prove di identità distinte: qualcosa che conosci (password), qualcosa che hai (smartphone, token), qualcosa che sei (impronta digitale, volto).
ASLR	Address Space Layout Randomization — Randomizzazione dello Spazio degli Indirizzi. Tecnica di sicurezza del sistema operativo che carica i programmi in posizioni casuali della memoria ad ogni avvio, rendendo molto più difficile sfruttare vulnerabilità come buffer overflow.
API	Application Programming Interface — Interfaccia di Programmazione. Insieme di protocolli che permette a sistemi software di comunicare. Le API esposte pubblicamente (es. API REST di un servizio web) aumentano la superficie di attacco del prodotto.
CAB	Conformity Assessment Body — Organismo di Valutazione della Conformità. Ente terzo indipendente accreditato per verificare la conformità dei prodotti alle normative. Per il CRA deve essere notificato alla Commissione Europea.
CE	Conformité Européenne — Conformità Europea. Marchio che attesta che il prodotto rispetta tutti i requisiti obbligatori delle normative UE applicabili. Per il CRA è obbligatorio dopo aver completato la procedura di conformità.
CI/CD	Continuous Integration / Continuous Deployment — Integrazione e Distribuzione Continua. Pratica di sviluppo software dove il codice viene testato e rilasciato automaticamente e di frequente, anziché in rilasci grandi e rari.
CISO	Chief Information Security Officer — Responsabile della Sicurezza delle Informazioni. Figura aziendale responsabile della strategia di cybersicurezza.
CRA	Cyber Resilience Act — Legge sulla Resilienza Cibernetica. Regolamento (UE) 2024/2847, la normativa europea sulla sicurezza informatica dei prodotti digitali.
CSIRT	Computer Security Incident Response Team — Team di Risposta agli Incidenti di Sicurezza. Ogni Stato Membro UE ha uno o più CSIRT nazionali. In Italia: CSIRT Italia dell'ACN (Agenzia per la Cybersicurezza Nazionale).
CVD	Coordinated Vulnerability Disclosure — Divulgazione Coordinata delle Vulnerabilità. Processo in cui un ricercatore segnala privatamente una vulnerabilità al produttore, che ha un periodo concordato per rilasciare una patch prima che la vulnerabilità venga resa pubblica.
CVE	Common Vulnerabilities and Exposures — Vulnerabilità ed Esposizioni Comuni. Sistema internazionale di catalogazione delle vulnerabilità software. Ogni vulnerabilità ottiene un codice univoco (es. CVE-2024-12345). Gestito da MITRE con supporto CISA.
CVSS	Common Vulnerability Scoring System — Sistema Comune di Punteggio delle Vulnerabilità. Scala 0-10 per la gravità: 0-3.9 Bassa, 4.0-6.9 Media, 7.0-8.9 Alta, 9.0-10.0 Critica.
CycloneDX	Standard OWASP per la creazione di SBOM in formato XML o JSON. Versione corrente: 1.6. È uno dei due formati riconosciuti dal CRA come valido per l'SBOM obbligatorio.
DAST	Dynamic Application Security Testing — Test Dinamico della Sicurezza. Tecnica di test che analizza un'applicazione in esecuzione cercando vulnerabilità, simulando un attaccante esterno. Strumenti: OWASP ZAP, Burp Suite.
DEP / NX	Data Execution Prevention / No-Execute — Prevenzione dell'Esecuzione dei Dati. Funzione hardware e software che impedisce l'esecuzione di codice in aree di memoria riservate ai dati, bloccando molti tipi di exploit.
DevSecOps	Development, Security, Operations. Approccio che integra la sicurezza in tutto il ciclo di sviluppo software, invece di trattarla come fase separata a fine progetto.

DDoS	Distributed Denial of Service — Attacco Distribuito di Negazione del Servizio. Attacco che usa molti sistemi compromessi contemporaneamente per sovraccaricare e rendere irraggiungibile un servizio o dispositivo.
ENISA	European Union Agency for Cybersecurity — Agenzia dell'UE per la Cybersicurezza. Sede ad Atene. Gestisce la piattaforma unica europea per la segnalazione degli incidenti CRA.
EUCS	EU Cybersecurity Certification Scheme — Schema Europeo di Certificazione della Cybersicurezza. Istituito dal Cybersecurity Act (Reg. UE 2019/881). Tre livelli: Basic, Substantial, High. Richiesto per i prodotti altamente critici del CRA.
HSM	Hardware Security Module — Modulo di Sicurezza Hardware. Dispositivo fisico tamper-resistant che esegue operazioni crittografiche in ambiente protetto. Usato per chiavi crittografiche di alto valore.
ICS / SCADA	Industrial Control Systems / Supervisory Control and Data Acquisition — Sistemi di Controllo Industriale. Usati in infrastrutture critiche: centrali elettriche, acquedotti, impianti produttivi.
IoT	Internet of Things — Internet delle Cose. Dispositivi fisici connessi a Internet che raccolgono e scambiano dati. Categoria principale soggetta al CRA: router, smart home, sensori industriali, ecc.
KEV	Known Exploited Vulnerabilities — Vulnerabilità Sfruttate Attivamente. Database CISA (USA) con CVE per cui esistono prove di sfruttamento in attacchi reali. La presenza in questo database determina l'obbligo di segnalazione CRA in 24 ore.
MDR	Medical Device Regulation — Regolamento Dispositivi Medici (UE) 2017/745. I dispositivi medici soggetti a MDR sono esclusi dal perimetro CRA.
NIS2	Network and Information Security Directive 2 — Direttiva (UE) 2022/2555. Si applica alle organizzazioni che gestiscono servizi essenziali. Complementare al CRA (che si applica ai prodotti, non alle organizzazioni).
PIE	Position Independent Executable — Eseguitibile Indipendente dalla Posizione. Tecnica di compilazione che permette all'eseguibile di essere caricato in qualsiasi zona di memoria, necessaria per l'efficacia dell'ASLR.
PMI	Piccole e Medie Imprese. Definizione UE: < 250 dipendenti e fatturato ≤ 50 milioni €. Microimpresa: < 10 dipendenti e fatturato/bilancio ≤ 2 milioni €. Accesso a procedure CRA semplificate.
PURL	Package URL — Identificatore Univoco del Pacchetto Software. Formato standardizzato per identificare componenti software negli SBOM. Esempio: pkg:npm/%40angular/core@17.0.0
RBAC	Role-Based Access Control — Controllo degli Accessi Basato sui Ruoli. I permessi sono assegnati a ruoli (es. admin, user, auditor), non a singoli utenti. Implementazione del principio del minimo privilegio.
SBOM	Software Bill of Materials — Distinta Base del Software. Inventario completo machine-readable di tutti i componenti software del prodotto. Obbligatorio per il CRA. Formati accettati: CycloneDX o SPDX.
SPDX	Software Package Data Exchange. Standard ISO/IEC 5962:2021 per SBOM. Sviluppato dalla Linux Foundation. Alternativa a CycloneDX, entrambi riconosciuti dal CRA.
STRIDE	Framework per threat modeling: Spoofing (furto identità), Tampering (manomissione dati), Repudiation (rifiuto di responsabilità), Information Disclosure (fuga di informazioni), Denial of Service (blocco servizi), Elevation of Privilege (escalation di privilegi).
TLS	Transport Layer Security — Sicurezza del Livello di Trasporto. Protocollo per la comunicazione cifrata su reti. Versione minima accettabile: TLS 1.2. Consigliata: TLS 1.3. Le versioni precedenti (SSL, TLS 1.0, 1.1) sono obsolete e non devono essere usate.
TPM	Trusted Platform Module — Modulo di Piattaforma Attendibile. Chip hardware dedicato alla sicurezza (standard ISO/IEC 11889) integrato in molti PC e server. Gestisce chiavi crittografiche e verifica l'integrità del sistema.

VEX

Vulnerability Exploitability Exchange — Scambio di Informazioni sulla Sfruttabilità. Documento machine-readable che specifica, per ogni CVE in un prodotto, se è effettivamente sfruttabile nel contesto specifico di quel prodotto.

Nota: questo documento è a scopo informativo e non costituisce parere legale. Fonte principale: Regolamento (UE) 2024/2847 disponibile su eur-lex.europa.eu